Evidence-based Policy Group Assessment

From Log Evidence to Security Policy

COMPSCI5077 – Enterprise Cyber Security

This assignment has a weighting of **20%** in calculating your grade for the course. Working in a group of **5–6 students**, you will find evidence of a cyber attack in server logs, use that evidence to build a risk assessment, and write a policy, with an implementation and evaluation plan, for the three highest-ranked risks.

1. Overview

The assessment is a single chain of reasoning. Each part depends on the one before it, as the chain below shows.

Logs → Evidence → Risk assessment → Policy → Implementation and evaluation

Your policy is the end product. It must be justified by your risk assessment, your risk assessment must be justified by evidence, and the evidence must come from your logs and from external sources. The report is marked by following this chain. A policy element with no risk behind it, or a risk with no evidence behind it, is a break in the chain.

Apparatus

You will need the following.

- a computer with Python available, a terminal, and a text editor or IDE
- the script and practice logs from the plenary, available on Moodle
- your group's two log files, `auth.log` and `daemon.log`, from the course Moodle
- access to the University Library and its databases for external sources

2. Background

Solstice Continental is a large fictional retailer with stores across several countries and a growing online business. Customer orders, including customer contact details and payment information, are held in a central PostgreSQL database (`orders`) on a Linux server. The database is backed up every night. Like many retailers, Solstice Continental gives remote access to a number of third-party contractors who maintain its stores and building systems.

The principal asset for this assessment is Solstice Continental's customer data, held in the `orders` database and its backups. It is central to the business. It supports sales, fulfilment, and customer service, and the organisation is legally responsible for protecting it.

Following reports of unusual activity, two log files have been recovered from the database server for the 90-day period in question, as follows.

- `auth.log` holds authentication and privilege events, including successful and failed logins, and commands run with `sudo`
- `daemon.log` holds the activity of system services, including the database, the scheduled task service (`cron`), and the nightly backup

Management have asked your team three questions. What happened? What risks does this expose for the customer data? What should the organisation do about the most serious of them?

Your logs are unique to your group. Every group investigates the same kind of incident, but addresses, account names, times, and counts differ between groups. Every value you report must come from your own group's logs.

Key Principle

Keep evidence and interpretation distinct.

Any quantitative statement about your logs should be produced by your script, and any individual entry you rely on should be quoted directly from the logs. Claims about the wider threat landscape, such as how prevalent an attack is or what it costs an organisation, need a cited source. Classifying activity as normal, suspicious or serious rests on your group's judgement, and your report should make the reasoning behind that judgement explicit.

3. Intended Learning Outcomes

This assessment targets four of the course's Intended Learning Outcomes, as follows.

- Identifying and critically assessing threats in a specific context
- Designing a policy response to a specific context
- Critiquing security policy and its justification
- Communicating cyber security concerns clearly to decision makers

4. Task

The report has four parts and must not exceed **6 pages**. The page count given for each part is guidance only, to help you balance the report. The title page, references, and appendices do not count towards the 6-page limit.

Part 1. Analysis

About 1.5 pages

Aim. Establish what happened, using evidence from your logs.

Run the script from the plenary on your two logs. Use its output, and your own reading of the logs, to find the following.

- **evidence of each attack**, meaning which of the attack techniques covered in lectures appear in your logs, and the log lines that show each one.
- **evidence of the chain**, meaning how the attacks connect, in order, from the first attempt to gain access through to what happened to the customer data.

Your analysis must include the outputs below.

Required output	What it must show
Source summary	The failed and successful logins for each source address, marked internal or external, as written by the script.
Evidence lines	For the attacker's address and for the compromised account, every line that mentions it in both logs, as written by the script. The full files may go in an appendix. Quote in the report the lines you rely on.
Table 1, Incident facts	The attacker's source address, the compromised account, and the date and time of the first access attempt, the first successful attacker login, privilege escalation, persistence, and the action against the customer data. Give the log line that shows each.
Table 2, Attack chain	Every stage of the attack in order, drawing on both logs, from the first access attempt to the last action against the customer data. For each stage give the time, the quoted log line, and what it shows.

Required analysis outputs.

You may add a chart or timeline, made with any tool, if it helps your reader.

State the rules you use to classify events (for example, which addresses you treat as internal, and what makes an event suspicious), and note any limitations or gaps in the evidence.

Part 2. Risk Assessment **About 2 pages**

Aim. Turn the evidence into a ranked set of risks to the customer data.

Step 1. Identify at least five risks

Each stage of the attack that succeeded exposes a control that was missing or failed. Stages that failed may show controls that worked. Use them as evidence of what is already in place. From your analysis, identify **at least five** risks to the customer data. For each risk, state the following.

- the weakness or missing control,
- what could happen to the customer data as a result, and
- the log evidence (from Part 1) that shows the weakness.

Step 2. Devise your rating scales and rate each risk

No rating scales are provided. **Devising them is part of the assessment.** Build your scales around the assets concerned.

First, list the assets that the attack touched or put at risk. The customer data in the `orders` database and its backups is the principal asset, and your logs may point to others, such as the database server and the accounts and credentials used to reach it. For each asset, say what matters about it (for example confidentiality, integrity, or availability) and what losing that would mean for Solstice Continental.

Then define two scales, each with several levels (five is typical), and include them in your report as a table.

- **Likelihood** is the chance that the weakness is exploited again in the next year, with the controls as they stand. Describe each level so that another reader could tell which level a risk belongs in.
- **Impact** is the consequence for the assets you listed. Describe each level in terms of those assets, for example how much data is exposed or lost, how long the business could not use it, and the legal, financial, and reputational consequences. Impact levels that could apply to any organisation, and so say nothing about these assets, will earn little credit.

Explain briefly why your scales suit this organisation, and how you combine the two ratings into a risk score (for example by multiplying them). Strengthen your scales with relevant external sources. For example, use published risk assessment frameworks, regulatory guidance, or data on what comparable incidents have cost, to justify your level definitions. Cite these sources.

Next, rate each risk using your scales, and justify every rating. Your logs show whether the control was absent and whether the attacker used the weakness here. External sources show how often attackers use this technique against comparable organisations, and what comparable incidents have cost organisations. Explain how the evidence combines. Do not rate every risk highly simply because the attack happened.

External sources must include academic literature, industry or government reports, and news reporting of real incidents. Cite **at least four** external sources across your risk assessment, including at least one peer-reviewed source. For every rating, say whether it rests on your logs, on an external source, or on both.

Step 3. Rank and select

Present your risks as a risk matrix and a ranked table, ordered by score. Select the **three** highest-ranked risks for Parts 3 and 4. Where scores are tied, explain how you decided the order. Explain briefly why the risks ranked fourth and below were not selected.

Checkpoint

For each risk, check that you can answer the following.

- What weakness does this risk describe, and what could happen to the customer data?
- Which log lines show it?
- Which level of each of your scales did you choose, and why?
- Which external sources support your scales and the likelihood and impact ratings?
- What uncertainty remains?

Part 3. Policy

About 1 page

Aim. Write a policy that addresses your three selected risks.

Write the policy as Solstice Continental would publish it, with its purpose, its scope (who and what it applies to), and a set of clear policy statements. Every policy statement must name the risk from Part 2 that it addresses, and each of your three risks must be addressed by at least one statement. The policy should be proportionate, meaning strong enough to reduce the risk, and not so demanding that the organisation could not follow it. **The policy should not be longer than one page.**

Part 4. Implementation & Evaluation

About 1.5 pages

Aim. Explain how the policy would be put in place, and how the organisation would know it had worked.

For each of your three risks, provide the following.

- an **implementation plan**, meaning what would change (technical, operational, or cultural), who is responsible, in what order, and over what timescale,
- **evaluation metrics**, identifying the metrics that are appropriate for judging whether the policy is working. For each metric, say what it measures, how and how often it would be collected, and what result would count as success, and
- the **residual risk** that would remain after the policy is in place.

Choose metrics that are relevant to the risk and measurable with data the organisation could realistically collect. Explain why each one is appropriate.

5. Use of AI

This assessment is **unsupervised**. Its School AI-use classification is **BROAD USE**. AI may be used to assist in completing the work, except in the ways prohibited below.

Permitted. You may use AI across the assessment process. For example, you may use it to understand the log format, to explain, modify, or debug `analysis.py`, to find candidate sources, and to help with the structure, presentation, and wording of your report.

Prohibited. The following must be your group's own analysis and judgement, and AI must not be used to produce them.

- the rules you use to classify events as normal, suspicious, or serious, and the conclusions you draw from the evidence (Part 1)
- your rating scales, the rating of each risk and its justification, and the ranking and selection of the three risks (Part 2)
- the policy statements (Part 3), and your choice of metrics and your judgement of residual risk (Part 4)

These are the judgements that this assessment exists to evidence. Using AI to make them would leave nothing for the marking to assess against the learning outcomes above.

Responsibility. AI output is not evidence. Every number in your report must come from your script's output, every log line you quote must come from your logs, and every external source must be one that your group has read and checked. All group members are responsible for everything the group submits.

Access. You are not required to use AI, and you are not required to buy a subscription to any AI service. University-approved AI functionality is available through Microsoft Copilot Chat with your University Microsoft 365 account. AI is also built into many editors, IDEs, search tools, and devices. These conditions apply to that functionality as well as to standalone AI services, so if you use such software, check what it does before you rely on it.

Declaration. Before any group work begins, your group must agree how it will use AI and declare that use via the course Moodle page, no later than Friday 16 October 2026. Your declaration must be in line with the permitted use of AI in this assessment, as set out in this section and in the School's group agreement on AI use, which is accessible on the course Moodle page. Your use of AI must be in line with your agreed declaration. Submit one binding joint declaration per group, not one per student.

Acknowledgement. Acknowledge all AI use at the end of the report, after the references. The acknowledgement does not count towards the 6-page limit. Your actual use of AI, and so your acknowledgement, must not exceed your agreed and declared use, and all group members are responsible for its accuracy. Follow the University's guidance on how to acknowledge and reference AI use.
`https://www.gla.ac.uk/myglasgow/sld/ai/students/#howtoacknowledgeandreferencegenaiuse,genaiinpractice-problematicuses`
For each tool, give its name, its version and publisher, how it was used, and which work is your own. There is no individual declaration, and no additional evidence of AI use is required. The two examples below show these four items applied to this exercise.

	Example A. Translating a source	Example B. Reading the logs
Tool	Microsoft Copilot Chat	Microsoft Copilot Chat
Version and publisher	M365 Copilot Chat, Microsoft	M365 Copilot Chat, Microsoft
How it was used	We found a Japanese-language news article about a data breach at a Japanese retailer and used Copilot to translate it into English, so that we could judge whether it was relevant to the likelihood and impact ratings in Part 2. We checked the figures and names in the translation against the original. We cite the original article, and where a claim relies on the translation we say so in the text.	We pasted one example `sudo` line from a public tutorial, not from our logs, and asked Copilot to explain its fields (user, terminal, working directory, target user, command), so that we could read our own `auth.log`. We did not ask it which events in our logs were suspicious.
Our own work	All risk ratings, ranking, and justifications. The translation was used only to understand the article, and we do not quote it as evidence.	All counts come from `analysis.py`. The classification rules, the events selected, Tables 1 and 2, and every later part are our own work.

6. Deliverables

Deliverable	Submission	Weight
Report (`report.pdf`), with a one-page Workload Record appendix (required)	Moodle	20%
`analysis.py` and the files it wrote	Moodle	
Personal Assessment of Contribution (optional)	Moodle (separate, individual)	

Deliverables and weighting.

Reference style. ACM Citation Style and Reference Format is recommended, and is described at `https://www.acm.org/publications/authors/reference-formatting`. Any widely accepted style is permitted provided it is used consistently.

7. Group Work, Workload Record, and Individual Grades

This is a group assessment. The sections below explain how your group works together, what to do if something goes wrong, and how individual grades are decided.

Working together

All communication between the members of your group about this assessment must be in English.

You will work in a group of 5–6 students allocated to you. The list of group members is on the course Moodle page. Look up the list, identify your group, contact each member, and schedule a meeting. Your group is responsible for scheduling its own meeting time outside class.

The Wednesday plenary is a physical check-in opportunity. You must attend in person each Wednesday and sit together as a group.

During the assessment, each student completes a group work wellbeing survey via the course Moodle page, by the date given in the Timetable.

If your group is struggling to contact or engage a member, inform the course coordinator as soon as possible. Do not wait for the next Wednesday plenary.

If your group has a problem

1. Set a meeting of the group, raise your concerns, settle on a solution, and note the meeting and the solution in the Workload Record.
2. If the group cannot settle on a solution, raise the problem with the course coordinator.
3. If a settled solution is not working, set another meeting, raise the concern that the solution is not being met, document it in the Workload Record, and raise it with the course coordinator.

Workload Record

Every group must include a one-page Workload Record as an appendix to the report, in any form the group considers appropriate, for example how the work was divided across reading the logs, running the script, the risk assessment, the policy, writing, review, and coordination. Groups may simply write **"All members contributed equally."** Keep the record up to date throughout the assessment, because it is also where your group records its Wednesday check-ins, its meetings, and any agreed solutions. A report submitted without a Workload Record is subject to the 2-band penalty for non-adherence to the submission instructions.

Personal Assessment of Contribution

Each member may also submit a private Personal Assessment of Contribution via Moodle, dividing 100 points across all members of the group, including themselves, to show their view of relative contribution. If a member does not submit one, this will be read as that member indicating that all members contributed equally.

Individual grades

The report receives a group mark. The Workload Record (including the Wednesday check-ins recorded in it) and the members' private Personal Assessments of Contribution are used to inform each member's final individual grade. A Personal Assessment of Contribution never sets a grade directly. Any difference between a member's grade and the group mark must be supported by the Workload Record. If these sources do not show unequal contribution, every member receives the group mark.

8. Submission

One nominated member of the group makes the submission via Moodle, and it is associated with all other members of the group. The other members can confirm what has been submitted by checking the submission link.

Package your group's work as a single zip file, uploaded via Moodle. Name the zip file using all group members' matriculation numbers, separated by underscores, ending in `_submission.zip`, for example `2345678_2345679_2345680_2345681_2345682_submission.zip`.

Submission Package Structure

```
<matriculation-numbers>_submission.zip/
report.pdf
analysis.py
source_summary.csv
evidence_*.txt
```

Running `python3 analysis.py` with your two logs in a folder named `logs/` must reproduce the source summary and evidence files. Put a short note at the top of `analysis.py` naming your group and the values you set for `INTERNAL_PREFIX` and `KEYS`. Each member's Personal Assessment of Contribution is submitted separately. Do not include it in the zip.

Checkpoint

Before submission, check the following.

- ☐ the source summary, Table 1 and Table 2 appear in the report, and every line quoted comes from your logs
- ☐ `analysis.py` and the files it wrote are in the zip
- ☐ your own rating scales, built around the assets concerned and strengthened by external sources, are included, and at least five risks are rated with them, each with log evidence and justified ratings
- ☐ at least four external sources are cited, at least one peer-reviewed
- ☐ the three selected risks are the three highest-ranked
- ☐ every policy statement names the risk it addresses, and the policy is no longer than one page
- ☐ the implementation plan and evaluation metrics cover all three risks
- ☐ the one-page Workload Record is included as an appendix to the report
- ☐ your group declared its AI use on the course Moodle page before starting, and the acknowledgement at the end of the report does not exceed that declared use

Report formatting. Label the team name and members clearly on the cover page. Use a 12-point font, 1-inch margins, and PDF format.

9. Timetable

Milestone	Date
Groups confirmed via Moodle	Friday 2 October 2026
Assessment specification released	Friday 9 October 2026
Group AI declaration	Friday 16 October 2026
Group wellbeing survey completed	Friday 30 October 2026
Assessment week, before the deadline	To be confirmed
Final report submission, 16:30	Wednesday 18 November 2026

10. Feedback

The final individual grade will be published via Moodle. General comments and feedback on the exercise will be provided to the class via Moodle. Team members may book an appointment to receive feedback on individual performance after release.

11. Marking Scheme

The report is assessed against the six criteria below, which carry the weights shown. For each criterion, academic judgement is used to decide which descriptor best fits the work overall. The descriptors are indicative rather than exhaustive, and a report may show features of more than one band or sit in different bands on different criteria. Grade labels and secondary bands follow Schedule A of the University's Code of Assessment, and within a band the secondary grade reflects how fully the descriptor is met.

Grade	**Analysis** (weight 25%)	**Risk Assessment** (weight 30%)	**Policy** (weight 20%)	**Implementation & Evaluation** (weight 15%)	**Written Quality** (weight 5%)	**Team Performance** (weight 5%)
A (A1–A5) excellent	Excellent analysis with thorough command of the evidence. Every attack technique is identified with correctly quoted log lines, and Tables 1 and 2 give a complete, accurate chain. Sound judgement in weighing alternative explanations and in separating what the logs show from what they suggest. Rules are explicit and well reasoned, and limitations are evaluated critically.	Excellent risk assessment. Scales are distinctive to this organisation, built around the assets concerned and strengthened by relevant external sources. Risks are distinct and tied to log evidence. Ratings are convincingly justified from the logs and well-chosen external sources (at least four, including a peer-reviewed source) and are differentiated. Ranking, selection and uncertainty show sound judgement.	Excellent policy that reads as one the organisation could publish. Statements are precise and proportionate and show sound judgement about trade-offs. Within one page, with every statement naming its risk and all three selected risks covered.	Excellent plans, realistic and specific about responsibilities, sequence, timescale and dependencies. Well-chosen, measurable metrics with success thresholds, and critical thought about what they might miss. Residual risk is considered critically.	Very clear, concise and persuasive for decision makers, within the page limit, with accurate, consistent references and professional presentation.	Excellent collaboration. The report reads as one coherent argument, and the Workload Record shows a fair division of work.
B (B1–B3) very good	Very good analysis. All or nearly all attack techniques are identified with correctly quoted log lines. Tables 1 and 2 are complete and accurate, or nearly so, and the chain is clear. Counts come from the script and match the group's logs. Rules are stated and limitations acknowledged.	Very good risk assessment. Scales are built around the assets concerned and supported by external sources. At least five distinct risks, tied to a weakness and to log evidence, with at most minor gaps. Ratings are well justified from the logs and external sources, the source requirement is met, and ratings are differentiated. Ranking and selection are consistent, with at most minor gaps in explaining ties or exclusions.	Clear, proportionate policy that is well informed by the analysis and risk assessment. Within one page. Every selected risk is addressed, and every or nearly every statement names its risk.	Realistic plan for each risk with responsibilities, sequence and timescale. Appropriate, measurable metrics, with how and when each is collected and what counts as success. Residual risk is discussed, with at most minor gaps.	Well structured and literate, within the page limit, with accurate references and only minor lapses in clarity or presentation.	Very good demonstration of team collaboration. Well integrated and coherent, and the Workload Record shows a fair division of work.
C (C1–C3) good	Most main attack techniques are identified. Tables mostly complete, but some entries are missing or some quoted lines do not fully support the claim. Rules partly stated and limitations noted only briefly.	Scales devised, but only loosely linked to the assets concerned. Five risks, but some weakly linked to log evidence. Justification is uneven, as some ratings are asserted, or most are rated highly. External sources adequate. Ranking consistent, with thin selection reasoning.	Statements reasonably clear, but some are vague, disproportionate or not traceable to a named risk. All three risks addressed, though not always convincingly.	Reasonable implementation plan, though responsibilities or sequence are sometimes unclear. Good identification of metrics, but some are vague or hard to measure. Residual risk discussed superficially.	Moderately well structured. Occasional lapses in clarity, grammar or referencing.	Good demonstration of team collaboration. Mostly integrated, with some uneven sections.
D (D1–D3) satisfactory	Some attack techniques are identified. Tables incomplete or with several errors, and the chain only partly reconstructed. Few rules stated and limitations rarely considered.	Scales are generic or poorly defined. Fewer than five risks, or several not tied to evidence. Ratings mostly asserted. External sources few or of doubtful reliability. Ranking or selection partly inconsistent.	Statements present but often unclear, generic or poorly linked to the selected risks. One or more risks not adequately addressed.	Thin implementation plan with unclear ownership. Some relevant metrics identified. Residual risk mentioned only in passing.	Adequately structured, but fairly often ungrammatical or unclear. Referencing inconsistent.	Adequate demonstration of team collaboration. Integrated in places but at times incoherent.
E (E1–E3) weak	Few attack techniques identified. Tables largely missing or incorrect, log lines rarely quoted or relevant, chain incoherent, and counts not traceable to the script.	Scales missing or unclear. Few, generic risks not linked to the logs. Ratings unjustified, with little or no external evidence. Ranking missing or inconsistent.	Policy vague, disproportionate or unrelated to the selected risks. Most risks not addressed.	Little or no implementation plan. Metrics absent or irrelevant.	Poorly structured and frequently ungrammatical, with weak or missing referencing.	Weak demonstration of team collaboration. Poorly integrated and incoherent.
F–G (F1–G2) poor, very poor	Almost no valid evidence. Tables missing or wrong, values do not come from the group's own logs, and no chain established.	No scales devised. No meaningful risk assessment, with risks absent or unrelated to the evidence and no ratings or ranking.	No clear policy, or one that does not follow from the analysis and risk assessment.	No clear plan for implementation or evaluation.	Very poorly structured and ungrammatical.	Poor demonstration of team collaboration. Poorly integrated.

12. Safe and Ethical Practice

This assessment uses provided log data for defensive analysis only. You must not attempt to access, scan, attack, or interact with any live system as part of this assessment. Recommendations should be framed as defensive measures. Where you discuss attacker behaviour, do so only to support defensive reasoning and risk communication.

13. Plagiarism and Integrity

Students are required to familiarise themselves with the University of Glasgow Plagiarism & Academic Integrity Code, available at `https://www.gla.ac.uk/myglasgow/apg/policies/uniregs/regulations2025-26/feesandgeneral/studentsupportandconductmatters/reg32/`. Student Learning Development (SLD) provides guidance on avoiding plagiarism at `https://www.gla.ac.uk/myglasgow/sld/`. If you are unsure what is deemed plagiarism, seek guidance from your lecturer, course coordinator, or adviser of studies.